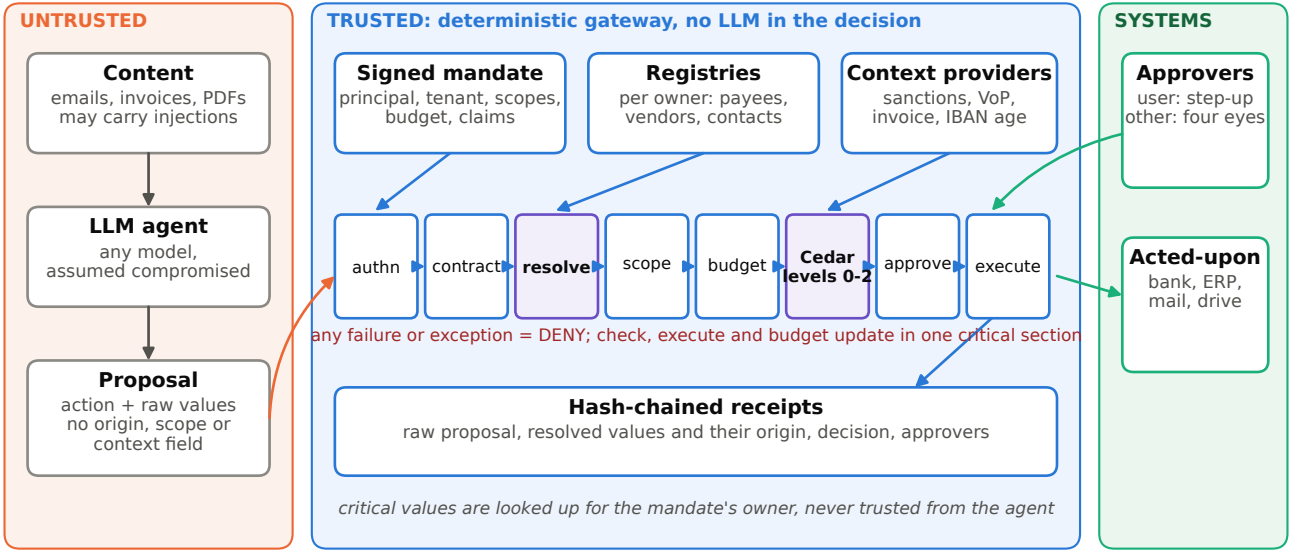
UNTRUSTED
Content
emails, invoices, PDFs
may carry injections
LLM agent
any model,
assumed compromised
Proposal
action + raw values
no origin, scope or
context field
TRUSTED: deterministic gateway, no LLM in the decision
Signed mandate
principal, tenant, scopes,
budget, claims
Registries
per owner: payees,
vendors, contacts
Context providers
sanctions, VoP,
invoice, IBAN age
authn
contract
resolve
scope
budget
Cedar
levels 0-2
approve
execute
any failure or exception = DENY; check, execute and budget update in one critical section
Hash-chained receipts
raw proposal, resolved values and their origin, decision, approvers
critical values are looked up for the mandate's owner, never trusted from the agent
SYSTEMS
Approvers
user: step-up
other: four eyes
Acted-upon
bank, ERP,
mail, drive